



ISACA X MLDS

Catching Phishing URLs with Logistic Regression

! <https://paypa1.com/login>

$P(\text{phishing}) = 0.94$

What is Phishing?

ISACA



Impersonation

Pretending to be someone you trust to steal logins, money, or data



Where it appears

Emails, text (“smishing”), phone calls (vishing), DMs, and even QR codes



What it asks you to do

Click a link, open an attachment, sign in, or send money.



What should you check?

The sender, the link, and the request



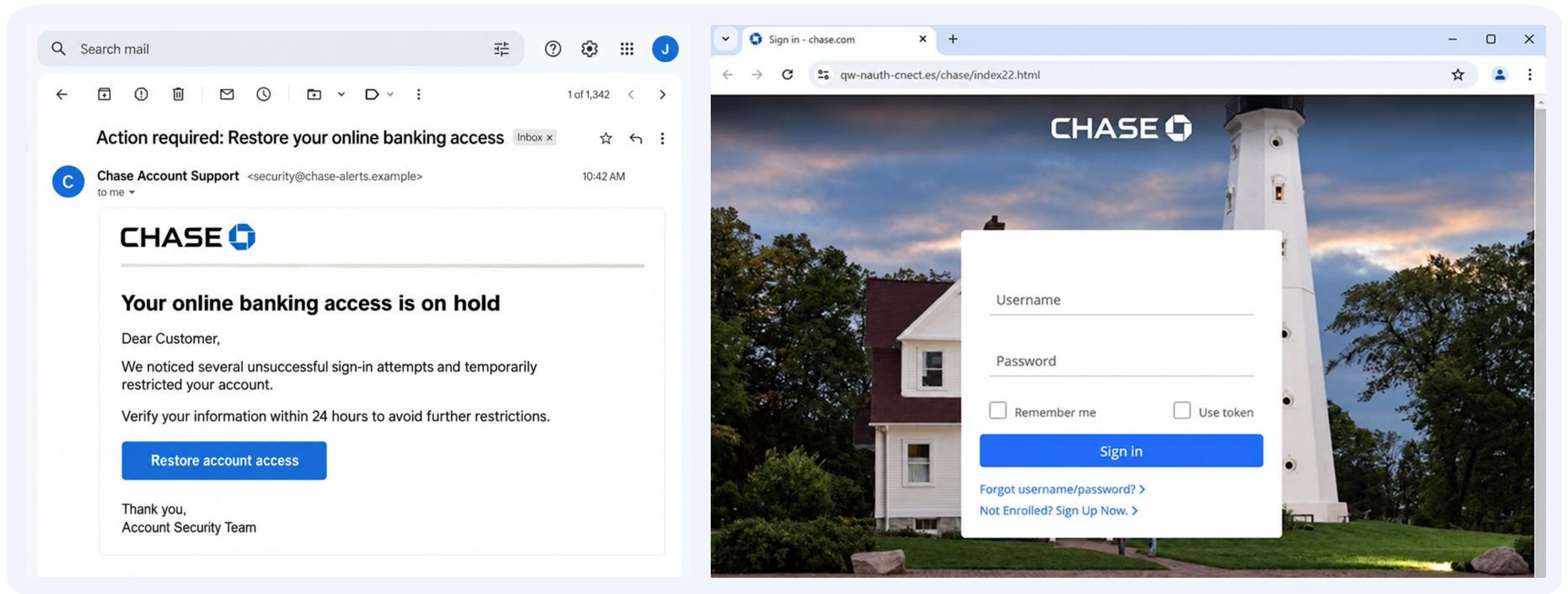
micr0soft.com

“Verify your account now”

Pressure to act quickly is a warning sign

Don't Let Urgency Fool You

ISACA



➔ Phishing messages often create urgency to make you click before you think.

Red flags Hiding in a Phishing URL

ISACA



Lookalike domain

`paypa1.com` `micr0soft.com`



Brand buried in a subdomain

`paypal.com.account-verify.xyz`



IP address instead of a name

`http://203.0.113.42/login`



“@” trick: browser ignores what’s before it

`https://bank.com@login-check.top`



Long, cluttered URL

`lots of digits, dashes, ?, =, &`



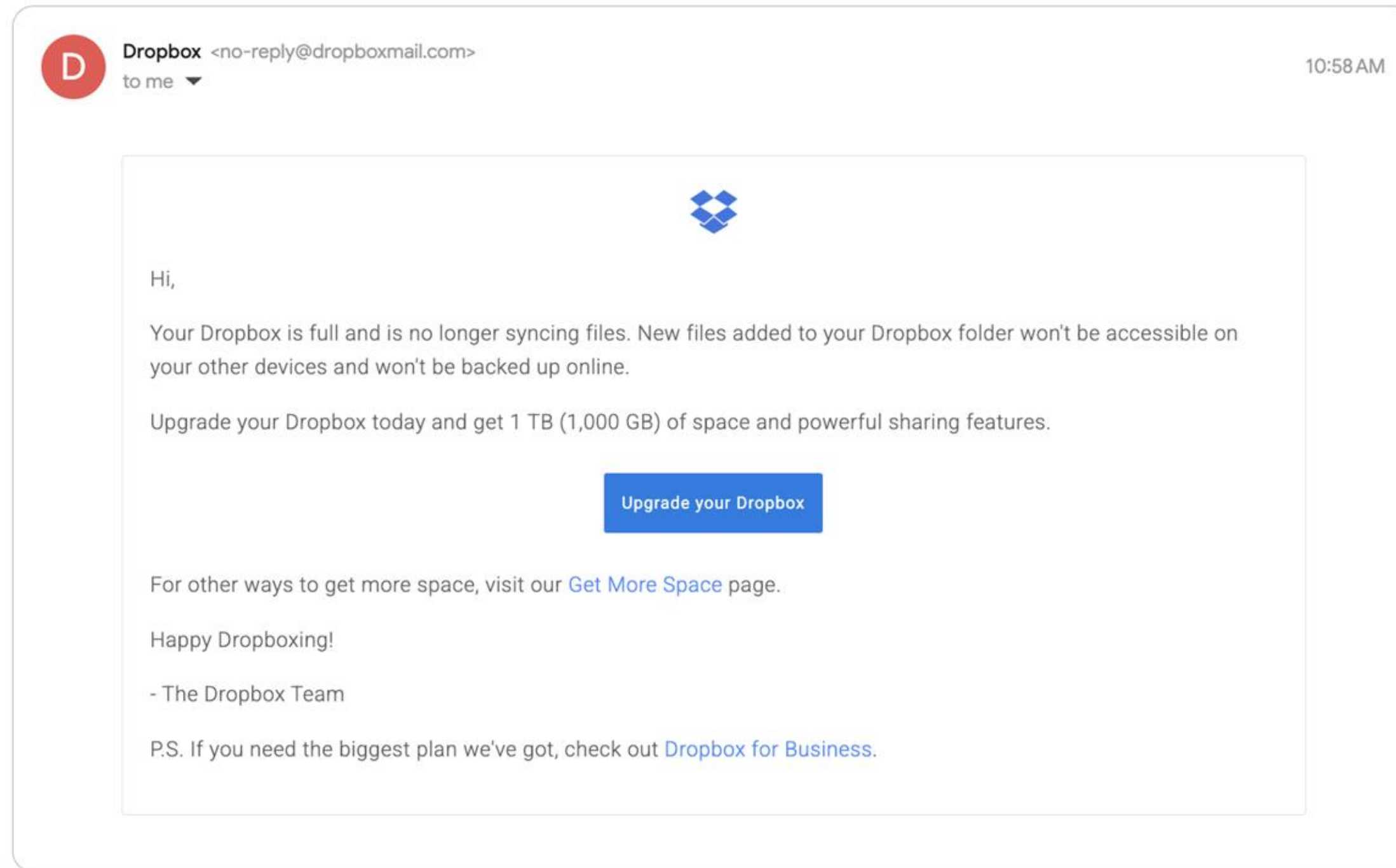
Unusual top-level domain

`.xyz` `.top` `.zip`

→ Each red flag becomes a **feature** (a column) in our model.

Let's Put This Into Practice!

ISACA



→ <https://phishingquiz.withgoogle.com/>

Why not just use a blacklist?

ISACA

Where blacklists fall short

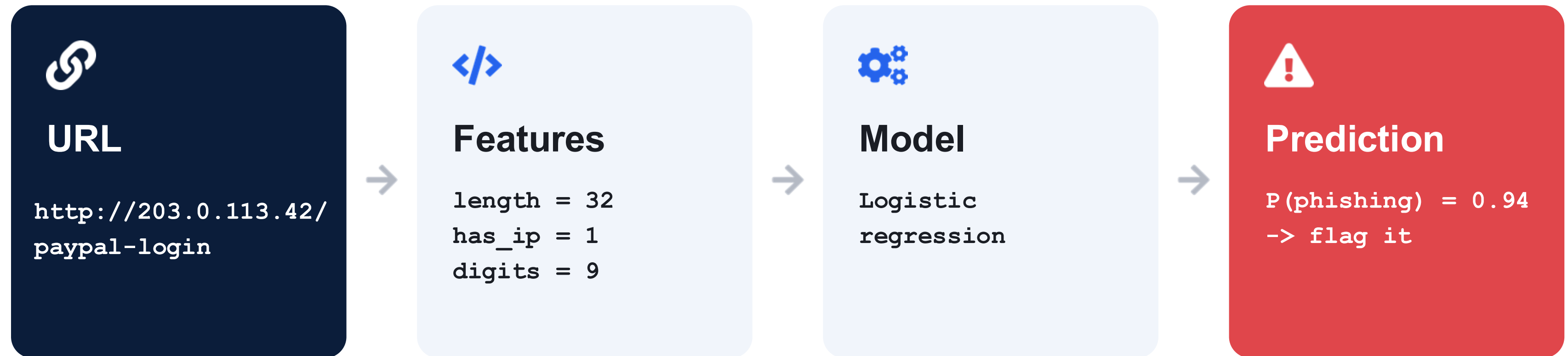
-  Only catch sites someone has already reported
-  Attackers register new domains constantly, and many phishing sites only stay up for a short time
-  People miss red flags when they're busy or on their phone



We want something that can...
**judge a URL it has
never seen before,
using only the URL**

Phishing as a classification problem

MLDS



Supervised learning: We train on URLs that are already labeled phishing or legitimate (we'll use the *PhiUSIL dataset*), then ask the model about new ones.

Logistic regression, in four key ideas

MLDS

1 Weighted sum

$$z = w_1x_1 + w_2x_2 + \dots + b = \sum_{i=1}^n w_ix_i + b$$

2 Squish to a probability

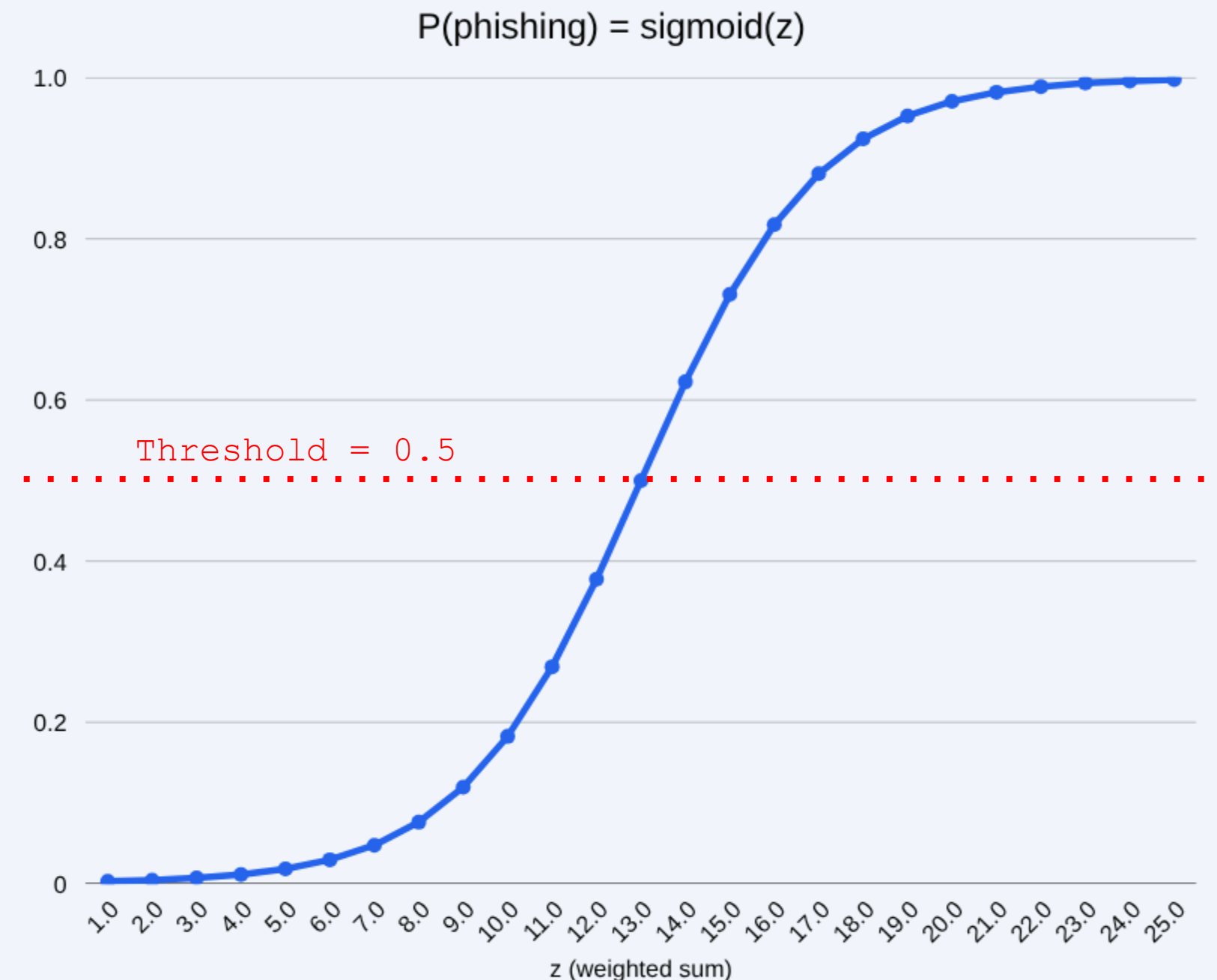
The sigmoid maps z to a number between 0 and 1

3 Readable weights

A big positive weight pushes toward “phishing”

4 Threshold

Above 0.5 (*by default, can be modified*) we call it phishing



What makes a good phishing detector?

Accuracy alone can be misleading: the two mistakes *don't* cost the same

Recall

Of all the phishing URLs, how many did we catch?

Precision

Of the URLs we flagged, how many were really phishing?

	Flagged	Not flagged
Phishing	Caught ✓	Missed ✗ Someone types their password into a fake site
Legit	False alarm A real site gets blocked	Fine ✓

 Lowering the threshold catches more phishing, but raises more false alarms

Rows: what the URL really is.
Columns: what the model said.

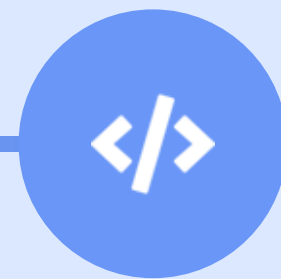
Building the detector

MLDS



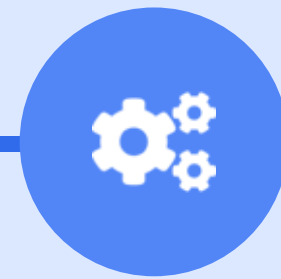
STEP 1

Load ~20k labeled URLs



STEP 2

Turn red flags into features with string methods



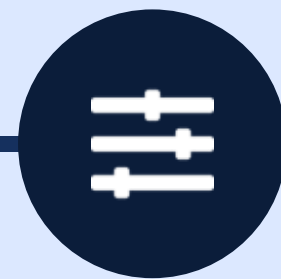
STEP 3

Train a logistic regression model



STEP 4

Read the weights and check the confusion matrix



STEP 5

Move the threshold and watch precision vs. recall trade off

Does the model think like an analyst?

MLDS × ISACA



Weights vs. flags

Did the biggest weights match ISACA's red flags?
Any surprises?



Blind spots

What kinds of phishing URLs did the model miss?



Challenge

Write a URL a person would flag but the model calls safe.

Implementation, in real life

MLDS × ISACA

01 **Deterministic layer**
Blocklist of known-bad sites

02 **First pass**
Logistic regression: fast, cheap, explainable

03 **Heavier ML**
Random Forests, XGBoost, or BERT/RoBERTa

Fast & cheap
Every URL

Slow & powerful
“Unsure” URLs